Resumen: La RTU - Control Distribuido en el Territorio

1. Introducción y Contexto

La **Unidad Terminal Remota (RTU)** es el dispositivo fundamental para gestionar infraestructuras críticas que se extienden por grandes territorios. A diferencia de los sistemas locales, la RTU habita en el "extremo más lejano", donde los controles de seguridad suelen ser más débiles.

- **Caso de estudio**: Incidente en Oldsmar, Florida (2021). Un atacante manipuló niveles químicos accediendo directamente a una computadora de campo, evadiendo la detección del servidor central.

2. Arquitectura Funcional de la RTU

Toda RTU se basa en cuatro capacidades esenciales:

Componente	Función	Riesgo en Ciberdefensa
CPU	Ejecuta lógica local y scripts de adquisición de datos.	Vulnerable a actualizaciones de firmware maliciosas.
Módulos de I/O	Reciben señales de sensores y activan actuadores físicos.	Punto donde el ataque se materializa (ej. apertura de válvulas).
Data Logger	Registra variables con marca de tiempo en memoria interna.	Fuente forense primaria; puede ser manipulado si no está cifrado.
Puerto de Comms	Interfaz con el canal hacia el centro de control.	Principal vector de ataque remoto.

3. El Modo Stand-Alone (Operación Autónoma)

Capacidad de la RTU para tomar decisiones de control local si se interrumpe el enlace con el centro de control (SCADA).

- **Resiliencia**: Permite que el sistema siga funcionando ante fallos de comunicación.
- **Riesgo**: Un adversario puede modificar esta lógica previamente para que la RTU actúe erróneamente durante un ataque coordinado.

4. Diferenciación Técnica

- **PLC**: Automatización industrial local (planta); ciclos en milisegundos; lenguaje Ladder.
- **RTU**: Supervisión remota y telemetría de campo; tolera latencia; gran dispersión geográfica.
- **IED**: Dispositivo específico para protección eléctrica; respuestas en microsegundos.

5. Medios de Comunicación y Ciberseguridad

- **Radio (VHF/UHF)**: Vulnerable a Jamming (interferencia) e inyección de paquetes.
- **Celular (3G/4G/5G)**: Dependencia de infraestructura civil; vulnerable a IMSI catchers.
- **Satélite (VSAT)**: Alta latencia y vulnerabilidad en el segmento de subida (uplink).

- **Protocolos (DNP3)**: Históricamente sin autenticación. Cualquier atacante con acceso puede emitir comandos de control.

6. Estrategia de Defensa en Profundidad

1. **Protección física**: Sensores de apertura en gabinetes (Tamper Switch).
2. **Seguridad lógica**: Implementación de DNP3 Secure Authentication v5 (IEEE 1815).
3. **Monitoreo**: Uso de IDS OT para detectar anomalías en el tráfico de red.
4. **Redundancia**: Canales de comunicación diversos para mitigar ataques de denegación de servicio físico.

Documento de Cátedra N° 7 - Licenciatura en Ciberdefensa (2026)

Resumen: La HMI - El Operador en el Loop de Control

1. Introducción y Concepto

La **Interfaz Hombre-Máquina (HMI)** es el punto de interacción entre el operador humano y el proceso industrial. Según el Documento de Cátedra N° 8, la HMI no es solo una pantalla, sino el elemento que permite la supervisión y el control del proceso físico.

- **Caso de estudio**: Ataque a la red eléctrica de Ucrania (2015). Los atacantes tomaron control de las HMIs para desconectar subestaciones y utilizaron "capturas de pantalla" estáticas para engañar a los operadores, ocultando el estado real de la crisis.

2. Funciones Principales de la HMI

Una HMI moderna debe cumplir con tres roles críticos para la operación:

1. **Visualización**: Representación gráfica del estado del proceso (presión, temperatura, estados de motores).
2. **Control**: Permite el envío de comandos (abrir/cerrar válvulas, cambiar consignas o setpoints).
3. **Gestión de Alarmas**: Notifica al operador sobre condiciones fuera de los límites normales.

3. Vulnerabilidades y Riesgos en Ciberdefensa

La HMI es un objetivo de alto valor porque controla la percepción del operador:

- **Secuestro de Sesión**: Los atacantes pueden tomar el control del cursor (como en el caso de Ucrania o Oldsmar).
- **Ataques de "Man-in-the-Middle" (MitM)**: Alteración de los datos que viajan hacia la pantalla para que el operador tome decisiones basadas en información falsa.
- **Sistemas Operativos Obsoletos**: Muchas HMIs corren sobre versiones antiguas de Windows (XP o 7), lo que facilita la explotación de vulnerabilidades conocidas.

4. El Factor Humano: "Situational Awareness"

El documento destaca que una HMI mal diseñada puede degradar la **Conciencia Situacional** del operador:

- **Fatiga por alarmas**: Demasiadas notificaciones irrelevantes causan que el operador ignore alarmas críticas.
- **Representación engañosa**: El uso excesivo de colores o gráficos 3D puede distraer de lo que realmente importa en una emergencia.

5. Estrategias de Protección (Defensa en Profundidad)

1. **Autenticación Robusta**: Uso de contraseñas fuertes y gestión de perfiles (operador vs. administrador).
2. **Segregación de Redes**: La HMI debe estar en una zona desmilitarizada (DMZ) o en una VLAN específica de control, aislada de la red corporativa e Internet.
3. **Endurecimiento (Hardening)**: Desactivar servicios innecesarios, puertos USB y software de acceso remoto no autorizado.
4. **Validación de Datos**: Comparar lo que muestra la HMI con instrumentos locales o sistemas de respaldo para detectar inconsistencias.

Documento de Cátedra N° 8 - Licenciatura en Ciberdefensa (2026)

Actividades de Verificación y Análisis - Unidad 2

1. Diferencia funcional entre Polling y Reporte por Excepción (RBE)

- **Diferencia Funcional:** * **Polling (Sondeo):** Es un método determinístico donde el Maestro (MTU) interroga secuencialmente a cada esclavo (RTU). La RTU solo responde cuando se le pregunta. Garantiza que el canal de comunicación funciona, pero consume mucho ancho de banda.
    - **RBE (Reporte por Excepción):** La RTU tiene autonomía para iniciar la comunicación solo cuando una variable cambia significativamente o cruza un umbral. Es altamente eficiente en el uso del ancho de banda, ideal para enlaces costosos o lentos (satélite/radio).
- **Escenario de Riesgo en Ataque:**
    - El **RBE** representa un riesgo mayor en ataques de **Supresión de Eventos**.
    - **Justificación:** En un sistema de Polling, si un atacante bloquea la comunicación, el Maestro detecta inmediatamente la falta de respuesta ("timeout"). En RBE, como el silencio es lo normal (significa que nada ha cambiado), un atacante puede interceptar y descartar selectivamente los paquetes de alarma de la RTU. El operador en el centro de control creerá que el proceso está estable cuando, en realidad, se está produciendo un incidente que la RTU intenta reportar sin éxito.

---

2. Disponibilidad en Redes Celulares y Ataques de Jamming

- **Contramedida ante fallo del proveedor (Cuestión de infraestructura):**
    - **Recomendación:** Implementar **Redundancia de Portadora o Multisim**.
    - **Justificación:** Al no existir un SLA (Acuerdo de Nivel de Servicio), el sistema es vulnerable a caídas masivas del proveedor. Utilizar módems con doble SIM de proveedores distintos garantiza

que, si una red cae, la RTU conmute automáticamente a la otra, manteniendo la visibilidad del proceso.

- **Contramedida ante Jamming deliberado (Ataque físico de RF):**
    - **Recomendación:** Implementar **Diversidad de Medios (Comunicación Híbrida)**.
    - **Justificación:** El Jamming satura una frecuencia específica (en este caso, las bandas de 4G). La única defensa efectiva es contar con un medio físico diferente, como un enlace de Radio VHF/UHF privado o una línea cableada, que opere en un espectro distinto al atacado, permitiendo que la RTU envíe la señal de alerta de "interferencia detectada".

---

3. Comparativa de Superficie de Ataque: PLC vs. RTU

- **Diferencia de Contexto:** El PLC está protegido por el "perímetro físico" de la planta (paredes, guardias, cámaras), mientras que la RTU está expuesta en gabinetes en la vía pública o descampados.
- **Tres Vectores de Ataque exclusivos para la RTU en este contexto:**
    1. **Manipulación Física del Hardware (Tampering):** Acceso directo a los bornes de I/O o puertos serie/USB para inyectar señales falsas o extraer el firmware directamente.
    2. **Ataque al Medio de Comunicación Inalámbrico:** Intercepción y spoofing de señales de radio o celular que viajan por el aire, vector inexistente en un PLC cableado dentro de una sala blindada.
    3. **Robo de Dispositivo para Ingeniería Inversa:** El atacante puede remover físicamente la RTU para analizarla en un laboratorio propio, obteniendo claves de cifrado o configuraciones que luego usará para atacar al resto de la red.
- **Efecto en la Doctrina de Defensa en Profundidad:** * Obliga a desplazar el control de seguridad al **propio dispositivo** (seguridad basada en el host). Al no poder confiar en el perímetro físico (primera capa de defensa), se vuelve mandatorio el uso de gabinetes con sensores de apertura (**Tamper Switches**), cifrado de datos extremo a extremo y autenticación fuerte en el protocolo (ej. DNP3-SA).

---

4. Análisis de Caso: Escucha Pasiva en Red de Gas

- **Información Valiosa de la Escucha Pasiva:**
    - **Mapeo de Activos:** Identificación de las direcciones IP y IDs de todas las RTUs activas.
    - **Lógica de Proceso:** Determinación de los rangos operativos normales (presiones, flujos) y los umbrales de alarma.
    - **Fingerprinting de Protocolos:** Identificación de versiones de firmware y protocolos específicos (ej. Modbus TCP sin seguridad) para buscar vulnerabilidades conocidas.
- **Fases del Ataque preparadas:**
    - **Reconocimiento:** Obtención de datos sobre la arquitectura de la red.
    - **Armamento / Preparación:** Desarrollo de comandos de control específicos basados en el tráfico observado (saber exactamente qué registro escribir para cerrar una válvula).
- **Medida de Seguridad que habría impedido la exfiltración:**

- **Cifrado de Capa de Red (VPN/IPsec) o de Capa de Aplicación:** El uso de túneles cifrados o la implementación de protocolos seguros (como DNP3 Secure Authentication) habría hecho que el tráfico interceptado fuera ilegible para el adversario, impidiéndole obtener inteligencia operativa.

Actividades de Verificación y Análisis - Unidad 2 (Parte II)

1. Conexión de HMI a Red Corporativa y Reportes

- **Riesgo de seguridad específico:** Esta decisión elimina el **aislamiento (Air-Gap)** o la segmentación lógica, introduciendo el riesgo de **Movimiento Lateral**. Al conectar la HMI directamente, cualquier amenaza que comprometa la red corporativa (como un Ransomware iniciado por un phishing en una oficina) puede saltar al entorno de control. Un atacante podría tomar control remoto de la HMI y, por ende, del proceso físico de la planta petroquímica.
- **Contramedida de Arquitectura Recomendada:** Implementación de una **DMZ Industrial (Zona Desmilitarizada)** con un servidor intermedio (*Historian* de réplica).
- **Justificación:** Se debe configurar un firewall que solo permita el tráfico de datos en un sentido (desde la HMI hacia la DMZ). La red corporativa consultará los reportes en el servidor de la DMZ, nunca directamente en la HMI. Esto permite la automatización de reportes manteniendo el loop de control aislado.

---

2. Clasificación del *Alarm Flooding* (Tríada AIC)

- **Principio Atacado Primariamente: Disponibilidad (Availability)**.
- **Justificación:** El ataque satura la capacidad del operador para procesar información. Al inundar la interfaz con miles de alertas, el sistema de supervisión deja de estar "disponible" para su función real: informar sobre el estado crítico del proceso.
- **Afectación a la Integridad (Ejemplo):**
  - **Escenario:** Un atacante genera una inundación de alarmas de baja prioridad en una planta química. El operador, desbordado y fatigado, decide silenciar el panel.
  - **Violación de Integridad:** Aprovechando el "ruido", el atacante inyecta un comando para alterar la mezcla de precursores químicos. El sensor genera una alarma legítima de "Reacción Exotérmica Inestable", pero esta se pierde entre las 500 alarmas falsas. El proceso físico se altera (integridad violada), pudiendo causar una explosión o un producto defectuoso, porque el operador perdió la capacidad de discernir la señal real.

---

3. Comparativa de Vectores: USB vs. Acceso Remoto

Criterio	USB (Caso Stuxnet)	Acceso Remoto (Caso Oldsmar)
Requisitos de acceso físico	**Alto:** Requiere que alguien inserte el dispositivo en la planta.	**Nulo/Bajo:** Se realiza a través de Internet o redes saltadas.
Detectabilidad (Red)	**Baja:** El malware opera localmente antes de intentar propagarse.	**Alta:** Deja logs de conexiones, intentos de login y tráfico RDP/VNC.
Dificultad de Contramedida	**Alta:** Requiere control de conducta humana y sellado físico.	**Media:** Se mitiga con MFA, VPNs y firewalls bien configurados.

- **Mayor Riesgo Actual:** El **Acceso Remoto sin protección**.
- **Justificación:** En el contexto de la convergencia IT/OT, la conectividad es la norma. Mientras que el USB requiere un esfuerzo logístico de inteligencia (insider), el acceso remoto permite a un atacante global explotar miles de plantas simultáneamente con herramientas automatizadas, aprovechando la debilidad de las credenciales y la falta de segmentación.

---

4. Análisis de Caso Integrador: Planta de Agua

Identificación de Fases y Tríada AIC

1. **Fase de Saturación (02:15):** Utilización de **Alarm Flooding**.
    - *Vulneración:* **Disponibilidad**. Se bloquea la capacidad de respuesta del operador.
2. **Fase de Inducción al Error (02:23):** El operador silencia el panel.
    - *Vulneración:* **Disponibilidad**. El lazo de control humano queda ciego voluntariamente.
3. **Fase de Ejecución/Ataque al Proceso (02:31):** Alteración de los niveles de cloro.
    - *Técnica:* Inyección de comandos de control.
    - *Vulneración:* **Integridad**. El proceso físico ha sido alterado maliciosamente.
4. **Fase de Ofuscación (Visualización):** La HMI muestra valores normales mientras el agua está contaminada.
    - *Técnica:* Manipulación de la interfaz / Captura de pantalla estática.
    - *Vulneración:* **Integridad de los datos**.
5. **Fase de Borrado de Huellas:** Sobreescritura del *Historian*.
    - *Vulneración:* **Integridad y Trazabilidad**. Se destruye la evidencia para impedir el análisis forense.

Contramedidas Recomendadas

- **Gestión de Alarmas (ISA-18.2):** Implementar priorización para que las alarmas críticas no puedan ser ocultadas por las de baja prioridad.
- **Validación Cruzada (Out-of-Band):** Un sistema que compare los datos de la red con sensores físicos independientes y genere una alerta sonora externa si hay discrepancia.
- **Seguridad en el Historian:** Configurar el servidor de datos como "solo lectura" para usuarios de red o implementar firmas digitales en los registros para evitar su alteración.
- **IDS OT:** Un sistema de detección de intrusos que hubiera alertado sobre la ráfaga anómala de comandos a las 02:15.

Documentos de Cátedra N° 7 y 8 - Licenciatura en Ciberdefensa (2026)